



IT-SIMPLERA INSTITUTE

Cyber Security Analyst Internship Program

WEEK 07-08 ASSIGNMENT

Cybersecurity Fundamentals & Security Concepts

Prepared by: Muhammad Awais and Muhammad Shaheer

Cyber Security Intern - Red Team

Supervisor / Mentor: Talal Rehan

Company: IT-SIMPLERA Solutions

Submission Deadline: 24 August 2026

Table of Contents

Executive Summary

1. Scope and Methodology
2. Assessment Objectives
3. Authorization and Ethical Considerations
4. Phase 1: Foundations and Network Design
5. Phase 2: Reconnaissance and OSINT
6. Phase 3: Enumeration and Scanning
7. Phase 4: Vulnerability Assessment
8. Remediation Recommendations
9. Incident Response Plan
10. Conclusion

Appendix A: Evidence and Screenshot Register

Appendix B: Scan Logs and Technical Evidence

Appendix C: References

Appendix D: Submission Checklist

Executive Summary

This assessment simulates an independent cybersecurity review of Nimbus Retail Co., a fictional organization preparing to launch a new e-commerce platform. The assessment follows the lifecycle defined by the IT-SIMPLERA Institute project brief, covering security foundations, network design, reconnaissance, enumeration, vulnerability assessment, cryptography and TLS, web application security, incident response, and professional reporting.

The practical assessment uses authorized training and laboratory environments. The working targets for this report are the Hack This Site training environment for web-focused activities and Metasploitable 2 for controlled network and service enumeration. Every target-specific statement must be supported by actual evidence collected by the assessment team.

1. Scope and Methodology

Scope Item	Description
Client	Nimbus Retail Co. (simulated)
Assessment Team	Muhammad Awais and Muhammad Shaheer
Training Organization	IT-SIMPLERA Institute
Web Target	Hack This Site, only the exact authorized training scope selected
Network Lab	Metasploitable 2, locally authorized
Approach	Passive reconnaissance, controlled enumeration, scanning, vulnerability research and reporting
Tools	Nmap, WHOIS, Subfinder/Amass, theHarvester, Gowitness, SSL Labs where applicable, browser, Word, PowerPoint and diagramming software, dig, httpx

Methodology: Phase 1 establishes security principles and network design. Phase 2 performs authorized reconnaissance and OSINT. Phase 3 performs structured enumeration and Nmap scanning. Phase 4 evaluates vulnerabilities, CVEs, CVSS, risk, TLS and incident response. Phase 5 consolidates the results into a client-ready report and presentation.

Limitations: Do not invent target information, vulnerabilities, CVEs, IP addresses, scan results or screenshots. If a target cannot satisfy a requirement, document the limitation and obtain an approved alternative target if the supervisor requires it.

2. Assessment Objectives

- Apply the CIA Triad to real-world scenarios.
- Design and document a segmented network architecture.
- Conduct passive and active OSINT on an authorized target.
- Use Nmap to enumerate services and fingerprint systems.
- Map findings to CVEs and assign CVSS severity.
- Explain cryptography and TLS.
- Identify relevant OWASP Top 10 style risks without unauthorized exploitation.
- Draft a practical incident response plan.
- Deliver a professional client-ready report and presentation.

3. Authorization and Ethical Considerations

The project brief requires all scanning, enumeration and testing to be performed only against instructor-provided or explicitly authorized lab targets. The team will restrict testing to the defined Hack This Site training scope and its own Metasploitable 2 laboratory machine. No destructive activity, denial of service, unauthorized access to third-party systems or testing outside scope is permitted.

4. Phase 1: Foundations and Network Design

Q1: CIA Triad and Recent Breaches

Breach	CIA Property	Analysis	Source
MGM Resorts Cybersecurity Incident (2023)	Availability	In September 2023, MGM Resorts suffered a cybersecurity incident that caused the company to shut down several systems. This resulted in major operational disruptions at its properties, including problems affecting bookings and other guest-facing systems. The incident therefore primarily violated Availability , because customers and employees temporarily could not use important services normally. MGM later reported	MGM Resorts SEC Filing

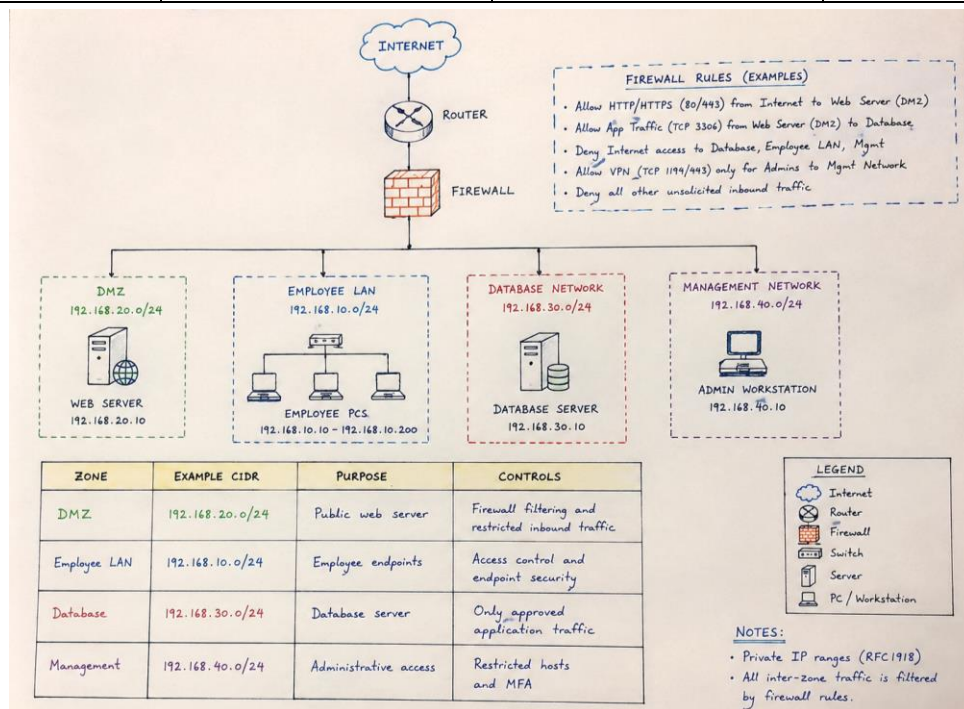
		that the disruption negatively affected its business operations and revenue. (SEC)	
Change Healthcare Cyberattack (2024)	Confidentiality & Availability	In February 2024, Change Healthcare was affected by a major ransomware attack that disrupted healthcare and billing systems across the United States. The incident resulted in a breach of protected health information, meaning sensitive patient information was exposed, violating Confidentiality . At the same time, the attack caused widespread disruption to healthcare transactions and services, affecting Availability as well. HHS later reported that approximately 192.7 million individuals were impacted. (HHS.gov)	HHS — Change Healthcare Cybersecurity Incident
Marks & Spencer Cyber Incident (2025)	Availability	In April 2025, Marks & Spencer experienced a sophisticated cyber incident that disrupted several of its operations. The company temporarily paused online orders, Click & Collect and some other services while it worked to contain the incident. This primarily affected Availability , because customers could not use important online shopping services normally. M&S later reported significant recovery costs and financial impact associated with the incident. (Marks & Spencer)	Marks & Spencer — Cyber Incident Update

Q2: Secure Small-Office Network Architecture

The proposed design separates public-facing services from internal resources. The web server is placed in a DMZ, the database server in a protected database subnet, and employee endpoints in an internal subnet. Firewall rules should allow only required traffic between zones.

Zone	Example CIDR	Purpose	Controls
DMZ	192.168.20.0/24	Public web server	Firewall filtering and restricted inbound traffic
Employee LAN	192.168.10.0/24	Employee endpoints	Access control and endpoint security
Database	192.168.30.0/24	Database server	Only approved application traffic

Management	192.168.40.0/24	Administrative access	Restricted hosts and MFA
------------	-----------------	-----------------------	--------------------------



Q3:

Seven OSI

Layers

Layer	What Happens When Customer Clicks “Buy Now” Button in UI
7 Application	Browser sends the purchase request to the e-commerce application using HTTP or HTTPS.
6 Presentation	Data is formatted and, when HTTPS is used, protected by the TLS stack.
5 Session	The communication session is established and maintained.
4 Transport	TCP provides delivery using source and destination ports and sequencing.
3 Network	IP addresses identify endpoints and routers forward packets.
2 Data Link	Frames carry packets over Ethernet or Wi-Fi using MAC addressing.
1 Physical	Bits travel over cable, fiber or wireless radio.

Q4: Least Privilege Access Control Policy

Purpose: Ensure employees receive only the access necessary for their assigned responsibilities.

- Access is granted according to job role and business need.
- Accounts are unique and must not be shared.
- Privileged access is separated from normal user access.
- MFA is required for administrative and sensitive systems where supported.
- Access is reviewed periodically and removed promptly when roles change or employment ends.
- Sensitive customer and database information is restricted to authorized roles.
- Administrative actions are logged and reviewed.
- Employees must not bypass security controls or install unauthorized software.

Policy Owner: [NAME]. Review Frequency: [PERIOD]. Approval: [APPROVER].

Phase 2: Reconnaissance and OSINT

Q5: OSINT Findings

The project requires at least eight findings using WHOIS, Google dorking, certificate transparency and social media. Record only information relevant to the authorized target.

ID	Technique	Finding	Evidence	Security Relevance
OSINT-1	WHOIS Enumeration	Domain registered with Porkbun LLC ; created 2003-08-10 and expires 2027-08-10 .	whois hackthissite.org	Reveals domain registration and lifecycle information useful for organizational reconnaissance.
OSINT-2	DNS Enumeration – NS Records	Five authoritative name servers identified: c.ns.buddyns.com, f.ns.buddyns.com, g.ns.buddyns.com, h.ns.buddyns.com, j.ns.buddyns.com.	dig NS hackthissite.org	Identifies the authoritative DNS infrastructure and potential DNS attack surface.
OSINT-3	DNS Enumeration – A Records	Domain resolves to five IPv4 addresses: 137.74.187.100–137.74.187.104.	dig A hackthissite.org	Reveals the IPv4 infrastructure associated with the domain and possible hosting endpoints.

OSINT-4	DNS Enumeration – MX Records	Email is handled through Google mail infrastructure , including aspmx.l.google.com and Goglemail MX servers.	dig MX hackthissite.org	Identifies the organization's external email provider and associated infrastructure.
OSINT-5	DNS Enumeration – TXT Records	TXT records expose an SPF policy and additional verification records, including v=spf1 ... -all.	dig TXT hackthissite.org	SPF information reveals authorized mail infrastructure and can help assess email-security configuration.
OSINT-6	DNS Enumeration – AAAA Records	No IPv6 address was returned for hackthissite.org; the response contains an SOA record instead.	dig AAAA hackthissite.org	Indicates that the queried domain currently does not advertise an IPv6 address, helping define the reachable network surface.
OSINT-7	Web Technology Fingerprinting	httpx identified HackThisSite and HSTS ; the site returned HTTP 503 Service Unavailable with the title HackThisSite.org Offline for Maintenance.	httpx -sc -title - tech-detect - server -ip	Reveals web-service behavior and security-related HTTP configuration while showing the site was unavailable during enumeration.
OSINT-8	Web Server / IP Enumeration	www.hackthissite.org resolved to 137.74.187.101 during the HTTP probe; HTTP response was 503 .	httpx -status- code -title - server -tech- detect -silent	Associates the web service with an IP address and provides information about its current availability.

```

(kali㉿kali)-[~]
$ whois hackthissite.org
Domain Name: hackthissite.org
Registry Domain ID: REDACTED
Registrar WHOIS Server: http://whois.porkbun.com
Registrar URL: https://porkbun.com
Updated Date: 2026-08-15T11:34:40Z
Creation Date: 2003-08-10T15:01:25Z
Registry Expiry Date: 2027-08-10T15:01:25Z
Registrar: Porkbun LLC
Registrar IANA ID: 1861
Registrar Abuse Contact Email: abuse@porkbun.com
Registrar Abuse Contact Phone: +1.8557675286
Domain Status: clientDeleteProhibited https://icann.org/epp#clientDeleteProhibited
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Name Server: c.ns.buddyns.com
Name Server: f.ns.buddyns.com
Name Server: g.ns.buddyns.com
Name Server: h.ns.buddyns.com
Name Server: j.ns.buddyns.com
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://icann.org/wicf/
>>> Last update of WHOIS database: 2026-08-24T08:13:05Z <<<

For more information on Whois status codes, please visit https://icann.org/epp

Terms of Use: Access to Public Interest Registry WHOIS information is provided to assist persons in determining the contents of a domain name registration record in the Public Interest Registry registry database. The data in this record is provided by Public Interest Registry for informational purposes only, and

```

```

(kali㉿kali)-[~]
$ dig NS hackthissite.org

; <<>> DiG 9.20.20-1-Debian <<>> NS hackthissite.org
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 28066
;; flags: qr rd ra; QUERY: 1, ANSWER: 5, AUTHORITY: 0, ADDITIONAL: 11

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
; COOKIE: 2bfcbef58b1e2e0f010000006a8bfd7c91ea548d22d15122 (good)
;; QUESTION SECTION:
hackthissite.org.                IN      NS

;; ANSWER SECTION:
hackthissite.org.                3495    IN      NS      j.ns.buddyns.com.
hackthissite.org.                3495    IN      NS      h.ns.buddyns.com.
hackthissite.org.                3495    IN      NS      c.ns.buddyns.com.
hackthissite.org.                3495    IN      NS      f.ns.buddyns.com.
hackthissite.org.                3495    IN      NS      g.ns.buddyns.com.

;; ADDITIONAL SECTION:
c.ns.buddyns.com.                47926   IN      A        116.203.6.3
f.ns.buddyns.com.                47735   IN      A        5.223.55.119
g.ns.buddyns.com.                72415   IN      A        192.184.93.99
h.ns.buddyns.com.                50174   IN      A        103.25.56.55
j.ns.buddyns.com.                50384   IN      A        37.143.61.179
c.ns.buddyns.com.                47926   IN      AAAA     2a01:4f8:1c0c:8115::3

```

```
(kali㉿kali)-[~]  
$ dig hackthissite.org  
  
; <<>> DiG 9.20.20-1-Debian <<>> hackthissite.org  
;; global options: +cmd  
;; Got answer:  
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 43878  
;; flags: qr rd ra; QUERY: 1, ANSWER: 5, AUTHORITY: 0, ADDITIONAL: 1  
  
;; OPT PSEUDOSECTION:  
; EDNS: version: 0, flags:; udp: 1232  
; COOKIE: aab025be0b55abd1010000006a8bfda78e549723b872b74f (good)  
;; QUESTION SECTION:  
;hackthissite.org.                IN      A  
  
;; ANSWER SECTION:  
hackthissite.org.      3453    IN      A      137.74.187.101  
hackthissite.org.      3453    IN      A      137.74.187.102  
hackthissite.org.      3453    IN      A      137.74.187.100  
hackthissite.org.      3453    IN      A      137.74.187.104  
hackthissite.org.      3453    IN      A      137.74.187.103  
  
;; Query time: 15 msec  
;; SERVER: 192.168.18.1#53(192.168.18.1) (UDP)  
;; WHEN: Mon Aug 24 13:15:00 PKT 2026  
;; MSG SIZE rcvd: 153
```

```

(kali㉿kali)-[~]
$ dig A hackthissite.org

;<>> DiG 9.20.20-1-Debian <>> A hackthissite.org
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 28787
;; flags: qr rd ra; QUERY: 1, ANSWER: 5, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 4096
;; QUESTION SECTION:
hackthissite.org.                IN      A

;; ANSWER SECTION:
hackthissite.org.                3421    IN      A      137.74.187.103
hackthissite.org.                3421    IN      A      137.74.187.104
hackthissite.org.                3421    IN      A      137.74.187.100
hackthissite.org.                3421    IN      A      137.74.187.102
hackthissite.org.                3421    IN      A      137.74.187.101

;; Query time: 31 msec
;; SERVER: 192.168.18.1#53(192.168.18.1) (UDP)
;; WHEN: Mon Aug 24 13:15:32 PKT 2026
;; MSG SIZE rcvd: 125

```

```

(kali㉿kali)-[~]
$ dig MX hackthissite.org

;<>> DiG 9.20.20-1-Debian <>> MX hackthissite.org
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 58547
;; flags: qr rd ra; QUERY: 1, ANSWER: 7, AUTHORITY: 0, ADDITIONAL: 11

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
; COOKIE: bc878fb534b6d904010000006a8bfdea5a13d6e3d31c5e58 (good)
;; QUESTION SECTION:
hackthissite.org.                IN      MX

;; ANSWER SECTION:
hackthissite.org.                3600    IN      MX      10 aspmx.l.google.com.
hackthissite.org.                3600    IN      MX      30 aspmx4.googlemail.com.
hackthissite.org.                3600    IN      MX      30 aspmx2.googlemail.com.
hackthissite.org.                3600    IN      MX      20 alt2.aspmx.l.google.com.
hackthissite.org.                3600    IN      MX      20 alt1.aspmx.l.google.com.
hackthissite.org.                3600    IN      MX      30 aspmx3.googlemail.com.
hackthissite.org.                3600    IN      MX      30 aspmx5.googlemail.com.

;; ADDITIONAL SECTION:
aspmx.l.google.com.              204     IN      A      74.125.206.27
alt1.aspmx.l.google.com.         205     IN      A      192.178.213.26
alt2.aspmx.l.google.com.         205     IN      A      142.251.127.26
aspmx2.googlemail.com.           205     IN      A      192.178.213.26
aspmx3.googlemail.com.           205     IN      A      172.253.152.26
aspmx.l.google.com.              204     IN      AAAA    2a00:1450:4001:c21::1b
alt1.aspmx.l.google.com.         205     IN      AAAA    2a00:1450:4013:c1e::1b
alt2.aspmx.l.google.com.         205     IN      AAAA    2a00:1450:4001:c21::1b
aspmx2.googlemail.com.           205     IN      AAAA    2a00:1450:4013:c1e::1a

```

```

(kali@kali)~$ dig TXT hackthissite.org

;<<>> DiG 9.20.20-1-Debian <<>> TXT hackthissite.org
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 14742
;; flags: qr rd ra; QUERY: 1, ANSWER: 4, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
;; EDNS: version: 0, flags:;, udp: 512
;; QUESTION SECTION:
;hackthissite.org.          IN      TXT

;; ANSWER SECTION:
hackthissite.org.          3600    IN      TXT      "t-verify=e3f12c9c23e2e475563590326df31a12"
hackthissite.org.          3600    IN      TXT      "v=spf1 a mx ip4:137.74.187.96 ip4:137.74.187.97 ip4:137.74.187.98 a:mail.hac
kthissite.org include:aspmx.googlemail.com include:spf.hackmail.org -all"
hackthissite.org.          3600    IN      TXT      "Harica-PM9RrLqWMFZXTJCoEoK"
hackthissite.org.          3600    IN      TXT      "Harica-9mEHYfxOM4FZwd9L0gg"

;; Query time: 222 msec
;; SERVER: 192.168.18.1#53(192.168.18.1) (UDP)
;; WHEN: Mon Aug 24 13:17:14 PKT 2026
;; MSG SIZE rcvd: 338

```

```

(kali@kali)~$ dig AAAA hackthissite.org

;<<>> DiG 9.20.20-1-Debian <<>> AAAA hackthissite.org
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 52589
;; flags: qr rd ra; QUERY: 1, ANSWER: 0, AUTHORITY: 1, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
;; EDNS: version: 0, flags:;, udp: 1232
;; COOKIE: 58765ef6a62d635a010000006a8bfe71131e6fcec93885b1 (good)
;; QUESTION SECTION:
;hackthissite.org.          IN      AAAA

;; AUTHORITY SECTION:
hackthissite.org.          3251    IN      SOA      c.ns.buddyns.com. admin.hackthissite.org. 2026040505 3600 900 1209600 3600

;; Query time: 19 msec
;; SERVER: 192.168.18.1#53(192.168.18.1) (UDP)
;; WHEN: Mon Aug 24 13:18:22 PKT 2026
;; MSG SIZE rcvd: 131

```

Certificate Viewer:
hackthisjogneh42n5o7gbzrewxee3vyu6ex37ukyvdw6jm66npakiy

GeneralDetails

Issued To

Common Name (CN)hackthisjogneh42n5o7gbzrewxee3vyu6ex37ukyvdw6jm66np
Organisation (O)<Not part of certificate>
Organisational Unit (OU)<Not part of certificate>

Issued By

Common Name (CN)HARICA DV TLS RSA
Organisation (O)Hellenic Academic and Research Institutions CA
Organisational Unit (OU)<Not part of certificate>

Validity Period

Issued OnWednesday, 25 March 2026 at 11:05:48
Expires OnSaturday, 10 October 2026 at 11:05:47

SHA-256 Fingerprints

Certificatedb7998a01c60ae753cc292c447b6988fd9f4b9d13d3b41d547c8e082cbc4364c
Public keyc3e638d5704f95972cd0e3b59552d5f9b130f94c40fa71f9ff3ac5c34f775d3f

Google site:hackthissite.org inurl:login

AI Mode **All** Images News Videos Forums Short videos More Tools

 Hack This Site
https://www.hackthissite.org

Hack This Site

HackThisSite.org is a free, safe and legal training ground for hackers to test and expand their ethical hacking skills with challenges, CTFs, and more.

 Hack This Site
https://www.hackthissite.org › user › view › intitle

View User: intitle

HackThisSite.org is a free, safe and legal training ground for hackers. Login (or Register): Lost your password? Forgot your username?

 Hack This Site
https://www.hackthissite.org › articles › read

What is OSINT and what are the most common techniques?

02-Jun-2021 — HackThisSite.org is a free, safe and legal training ground for hackers. Login (or

Google site:hackthissite.org inurl:forum

AI Mode **All** Short videos Images News Videos Forums More Tools

 Hack This Site
https://hackthissite.org

Hack This Site

Join our IRC, Discord, and our forums where users can discuss hacking, network security, and more. Tune in to the hacker underground and get involved with the ... [Read more](#)

 Hack This Site
https://www.hackthissite.org › register

Register

HackThisSite.org is a free, safe and legal training ground for hackers to test and expand their ethical hacking skills with challenges, CTFs, and more.

 Hack This Site
https://www.hackthissite.org › user › view

Hack This Site :: View User: HackThisSite Staff

HackThisSite.org is a free, safe and legal training ground for hackers to test and expand their ethical

```
(kali@kali)-[~]
$ echo "https://www.hackthissite.org" | httpx -sc -title -tech-detect -server -ip

projectdiscovery.io

[INF] Current httpx version v1.9.0 (outdated)
[WRN] UI Dashboard is disabled. Use -dashboard option to enable
https://www.hackthissite.org [503] [HackThisSite.org | Offline for Maintenance] [HackThisSite] [137.74.187.101] [HSTS]
```

Q6: Subdomain Enumeration

Requirement: at least ten legitimate subdomains. Do not fabricate entries. If the authorized target does not provide ten subdomains, document the limitation and obtain an alternative approved target if required.

#	Subdomain	Source	Status	Evidence
1	irc.hackthissite.org	httpx, subfinder	301	https://irc.hackthissite.org [301]
2	irc-lille.hackthissite.org	httpx, subfinder	301	https://irc-lille.hackthissite.org [301]
3	irc-wolf.hackthissite.org	httpx, subfinder	301	https://irc-wolf.hackthissite.org [301]
4	0-v3dev-cdn.hackthissite.org	httpx, subfinder	400	http://0-v3dev-cdn.hackthissite.org [400]
5	lille.irc.hackthissite.org	httpx, subfinder	301	https://lille.irc.hackthissite.org [301]
6	3-v3dev-cdn.hackthissite.org	httpx, subfinder	400	http://3-v3dev-cdn.hackthissite.org [400]
7	h5ai.hackthissite.org	httpx, subfinder	200	https://h5ai.hackthissite.org [200]
8	1-v3stage-cdn.hackthissite.org	httpx, subfinder	400	http://1-v3stage-cdn.hackthissite.org [400]
9	hub.irc.hackthissite.org	httpx, subfinder	400	http://hub.irc.hackthissite.org [400]
10	ctf.hackthissite.org	httpx, subfinder	200	https://ctf.hackthissite.org [200]

```
(kali㉿kali)-[~]
$ subfinder -d hackthissite.org -o subDomains.txt
```

```

  _____
 /  _  _  _  \
|  _ \| | | | | | |
| |_) | | | | |
|  _ \| | | | |
|_| \_|_|_|_|_|

```

projectdiscovery.io

```
[INF] Current subfinder version v2.16.0 (latest)
[INF] Loading provider config from /home/kali/.config/subfinder/provider-config.yaml
[INF] Enumerating subdomains for hackthissite.org
0-v3dev-cdn.hackthissite.org
v3dev-cdn.hackthissite.org
status-new.hackthissite.org
gitlab.hackthissite.org
test.hackthissite.org
u003eirc.hackthissite.org
v3stage-cdn.hackthissite.org
vm-005.outbound.firewall.hackthissite.org
forums.hackthissite.org
www.irc.hackthissite.org
irc-v6.hackthissite.org
jupiter.hackthissite.org
v3dev.hackthissite.org
live.hackthissite.org
hp.hackthissite.org
int.hackthissite.org
stats.hackthissite.org
wolf.irc.hackthissite.org
1-v3stage-cdn.hackthissite.org
2-v3dev-cdn.hackthissite.org
```

```
(kali㉿kali)-[~]
$ cat subDomains.txt | httpx -status-code
```

```

  _____
 /  _  _  _  \
|  _ \| | | | | | |
| |_) | | | | |
|  _ \| | | | |
|_| \_|_|_|_|_|

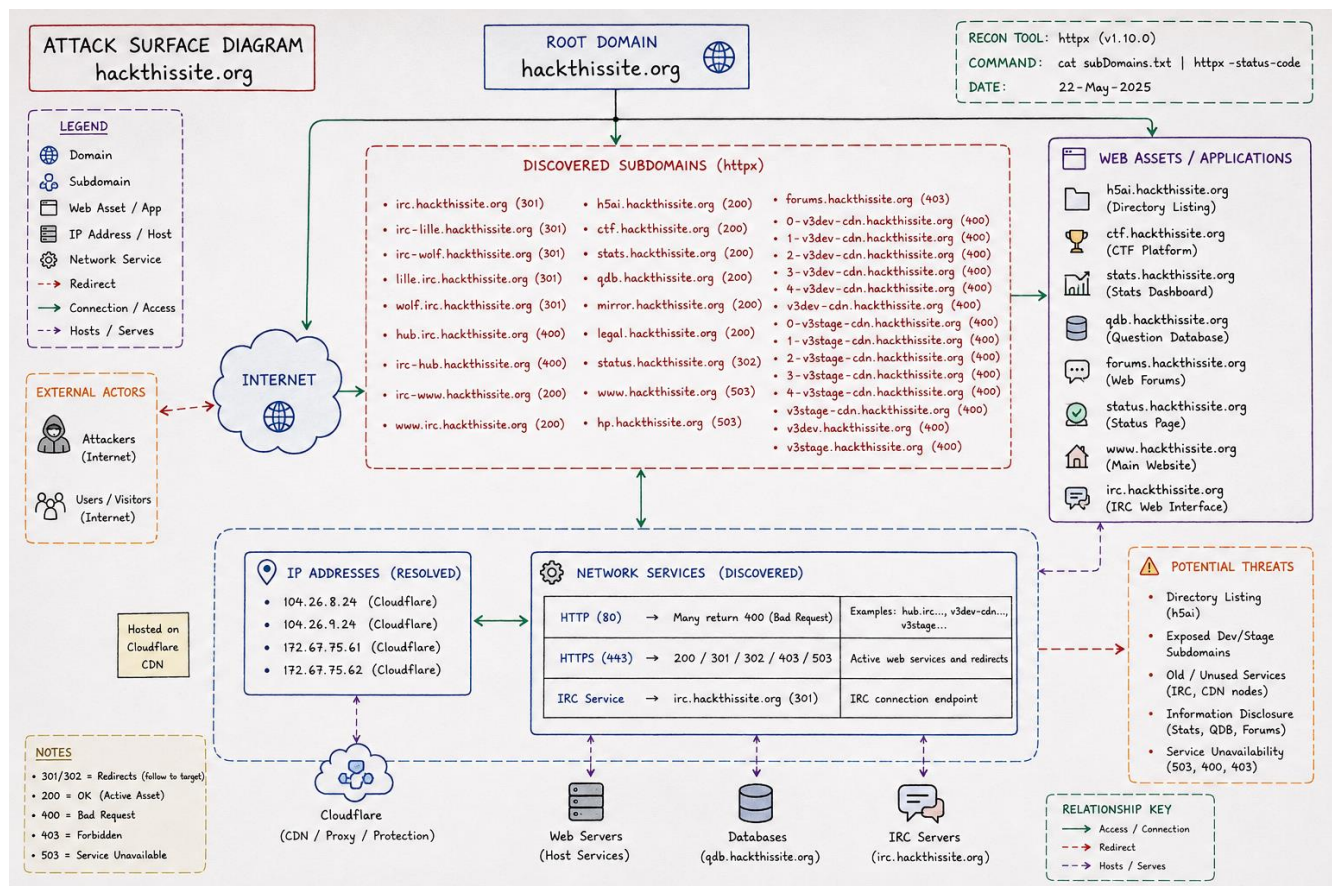
```

projectdiscovery.io

```
[INF] Current httpx version v1.10.0 (latest)
[WRN] UI Dashboard is disabled, Use -dashboard option to enable
https://irc.hackthissite.org [301]
https://irc-lille.hackthissite.org [301]
https://irc-wolf.hackthissite.org [301]
http://0-v3dev-cdn.hackthissite.org [400]
https://lille.irc.hackthissite.org [301]
http://3-v3dev-cdn.hackthissite.org [400]
https://h5ai.hackthissite.org [200]
http://1-v3stage-cdn.hackthissite.org [400]
http://hub.irc.hackthissite.org [400]
https://ctf.hackthissite.org [200]
http://0-v3stage-cdn.hackthissite.org [400]
https://stats.hackthissite.org [200]
http://irc-hub.hackthissite.org [400]
http://1-v3dev-cdn.hackthissite.org [400]
https://irc-www.hackthissite.org [200]
https://qdb.hackthissite.org [200]
http://2-v3dev-cdn.hackthissite.org [400]
http://3-v3stage-cdn.hackthissite.org [400]
http://2-v3stage-cdn.hackthissite.org [400]
https://mirror.hackthissite.org [200]
```


Q7: Attack Surface Diagram

Create a diagram showing verified domains, subdomains, web assets, IP addresses and network services and how they relate.



Phase 3: Enumeration and Scanning

Q8: Four Nmap Scan Types

Target: Metasploitable 2 virtual machine (192.168.18.152) was used as the authorized lab target for all Nmap scans. The scans were performed within the isolated lab environment for security testing and reconnaissance purposes.

ID	Scan Type	Command	Purpose	Key Result	Speed
N1	Default TCP Scan	nmap 192.168.18.152	Default top 1000 TCP ports ko scan karke open ports identify karna	23 TCP ports open; services such as FTP, SSH, Telnet, HTTP, MySQL, PostgreSQL, VNC, etc. found	0.93 s

N2	Service Version Detection	nmap -sV 192.168.18.152	Open ports par running services aur unki versions identify karna	Detailed versions found, e.g. vsftpd 2.3.4, OpenSSH 4.7p1, Apache 2.2.8, MySQL 5.0.51a, PostgreSQL 8.3.0-8.3.7	12.52 s
N3	OS Detection	nmap -O 192.168.18.152	Target ka probable operating system identify karna	Linux 2.6.X , specifically estimated Linux 2.6.9-2.6.33 ; network distance 1 hop	2.34 s
N4	TCP SYN Scan	nmap -sS 192.168.18.152	SYN-based TCP port scan se open TCP ports identify karna	Same 23 open TCP ports identified; results were consistent with the default scan	0.95 s

```
(kali@kali)-[~]
$ nmap 192.168.18.152
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-24 14:12 +0500
Nmap scan report for 192.168.18.152
Host is up (0.0020s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  vnc
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown

(kali@kali)-[~]
$ nmap -sS 192.168.18.152
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-24 14:12 +0500
Nmap scan report for 192.168.18.152
Host is up (0.0029s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  vnc
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:0C:29:17:85:4E (VMware)

(kali@kali)-[~]
$ nmap -sV 192.168.18.152
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-24 14:13 +0500
Nmap scan report for 192.168.18.152
Host is up (0.0032s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VE
RSION
21/tcp    open  ftp          vs
22/tcp    open  ssh          0p
23/tcp    open  telnet       Li
25/tcp    open  smtp         Po
53/tcp    open  domain       IS
80/tcp    open  http         Ap
111/tcp   open  rpcbind      2
139/tcp   open  netbios-ssn Sa
1524/tcp  open  ingreslock   V/2)
2049/tcp  open  nfs          (RPC #100000)
2121/tcp  open  ccproxy-ftp  mba smb
3306/tcp  open  mysql        d 3.X - 4.X (workgroup
5432/tcp  open  postgresql   : WORKGROUP)
5900/tcp  open  vnc          445/tcp
6000/tcp  open  vnc          open netbios-ssn Sa
6667/tcp  open  irc          mba smb
8009/tcp  open  ajp13        d 3.X - 4.X (workgroup
8180/tcp  open  unknown     : WORKGROUP)
MAC Address: 00:0C:29:17:85:4E (VMware)

(kali@kali)-[~]
$ nmap -O 192.168.18.152
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-24 14:13 +0500
Nmap scan report for 192.168.18.152
Host is up (0.0016s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  vnc
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:0C:29:17:85:4E (VMware)
```

Q9: Open Ports,

Versions and Banner Grabbing

Services,

```
(kali@kali)-[~]
$ nc 192.168.18.152 21
220 (vsFTPd 2.3.4)
^C

(kali@kali)-[~]
$ nc 192.168.18.152 22
SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1
^C
```

Port	Protocol	Service	Exact Version	Evidence	Banner Method
21	TCP	FTP	vsftpd 2.3.4	21/tcp open ftp vsftpd 2.3.4	Nmap -sV
22	TCP	SSH	OpenSSH 4.7p1 Debian 8ubuntu1	22/tcp open ssh OpenSSH 4.7p1 Debian 8ubuntu1	Nmap -sV

23	TCP	Telnet	Linux telnetd	23/tcp open telnet Linux telnetd	Nmap -sV
25	TCP	SMTP	Postfix smtpd	25/tcp open smtp Postfix smtpd	Nmap -sV
53	TCP	DNS	ISC BIND 9.4.2	53/tcp open domain ISC BIND 9.4.2	Nmap -sV
80	TCP	HTTP	Apache httpd 2.2.8 (Ubuntu)	80/tcp open http Apache httpd 2.2.8 ((Ubuntu) DAV/2)	Nmap -sV
111	TCP	RPCbind	RPCbind 2	111/tcp open rpcbind 2 (RPC #100000)	Nmap -sV
139	TCP	NetBIOS/SMB	Samba smbd 3.X-4.X	139/tcp open netbios-ssn Samba smbd 3.X - 4.X	Nmap -sV
445	TCP	SMB	Samba smbd 3.X-4.X	445/tcp open netbios-ssn Samba smbd 3.X - 4.X	Nmap -sV
512	TCP	rexec	netkit-rsh rexecd	512/tcp open exec netkit-rsh rexecd	Nmap -sV
513	TCP	rlogin	OpenBSD/Solaris rlogind	513/tcp open login OpenBSD or Solaris rlogind	Nmap -sV
514	TCP	shell	tcpwrapped	514/tcp open tcpwrapped	Nmap -sV
1099	TCP	Java RMI	GNU Classpath grmiregistry	1099/tcp open java-rmi GNU Classpath grmiregistry	Nmap -sV
1524	TCP	Bindshell	Metasploitable root shell	1524/tcp open bindshell Metasploitable root shell	Nmap -sV
2049	TCP	NFS	NFS 2-4	2049/tcp open nfs 2-4 (RPC #100003)	Nmap -sV
2121	TCP	FTP	ProFTPD 1.3.1	2121/tcp open ftp ProFTPD 1.3.1	Nmap -sV
3306	TCP	MySQL	MySQL 5.0.51a-3ubuntu5	3306/tcp open mysql MySQL 5.0.51a-3ubuntu5	Nmap -sV
5432	TCP	PostgreSQL	PostgreSQL 8.3.0-8.3.7	5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7	Nmap -sV
5900	TCP	VNC	VNC protocol 3.3	5900/tcp open vnc VNC (protocol 3.3)	Nmap -sV
6000	TCP	X11	X11	6000/tcp open X11 (access denied)	Nmap -sV
6667	TCP	IRC	UnrealIRCd	6667/tcp open irc UnrealIRCd	Nmap -sV
8009	TCP	AJP13	Apache Jserv Protocol v1.3	8009/tcp open ajp13 Apache Jserv (Protocol v1.3)	Nmap -sV
8180	TCP	HTTP	Apache Tomcat/Coyote JSP engine 1.1	8180/tcp open http Apache Tomcat/Coyote JSP engine 1.1	Nmap -sV

Web Technology and OWASP Relevance

Technology Area	Observed Technology	Evidence	Relevant OWASP Category	Reason
Web Server	HackThisSite web application; IP 137.74.187.104	httpx → [200] [Hack This Site] [HackThisSite] [137.74.187.104] [HSTS,jQuery:1.8.1]	A05: Security Misconfiguration	The scan confirms an accessible web service and reveals technology/infrastructure information that can assist reconnaissance.
Framework	No framework identified	httpx -tech-detect → HSTS,jQuery:1.8.1	A06: Vulnerable and Outdated Components	No specific server-side framework was detected, so a framework should not be assumed.
Client Side	jQuery 1.8.1	httpx → jQuery:1.8.1	A06: Vulnerable and Outdated Components	The detected jQuery version is an older client-side library and should be assessed for known vulnerabilities and upgrade requirements.
Database/API	Not identified	No database/API technology was reported by the httpx scan	N/A	The available evidence does not identify a specific database or API, so no OWASP category can be confidently assigned.

```

(kali@kali)-[~]
$ echo "https://www.hackthissite.org" | httpx -status-code -title -server -tech-detect -ip

projectdiscovery.io

[INF] Current httpx version v1.10.0 (latest)
[WRN] UI Dashboard is disabled, Use -dashboard option to enable
https://www.hackthissite.org [200] [Hack This Site] [HackThisSite] [137.74.187.104] [HSTS,jQuery:1.8.1]

```

Phase 4: Vulnerability Assessment

Q11: CVE Mapping

Use the NVD to verify at least three discovered service/version combinations. A CVE should be recorded only when the affected product and version match the observed evidence.

ID	Asset	Port	Product / Version	CVE	NVD Evidence	Version Match
VULN-01	192.168.18.152	21/TCP	vsftpd 2.3.4	CVE-2011-2523	NVD identifies vsftpd 2.3.4 as affected. (NVD)	YES
VULN-02	192.168.18.152	22/TCP	OpenSSH 4.7p1	CVE-2008-5161	NVD explicitly mentions OpenSSH 4.7p1 as affected. (NVD)	YES
VULN-03	192.168.18.152	80/TCP	Apache httpd 2.2.8 (Ubuntu)	CVE-2017-7679	NVD states the vulnerability affects Apache httpd 2.2.x before 2.2.33 , which includes the observed 2.2.8 . (NVD)	YES

Q12: CVSS Severity

Finding	CVE	CVSS Version	Base Score	Severity	Justification
VULN-01 — vsftpd 2.3.4	CVE-2011-2523	CVSS 3.1	9.8	Critical	The vulnerable vsftpd 2.3.4 contains a backdoor that can be triggered remotely without authentication, potentially providing shell access. NVD rates it 9.8 Critical with network attack vector, low complexity, no privileges, and high impact on confidentiality, integrity and availability. (NVD)
VULN-02 — OpenSSH 4.7p1	CVE-2008-5161	CVSS 3.1	3.7	Low	The vulnerability concerns CBC-mode SSH connections and can allow recovery of certain plaintext data. CISA-ADP's CVSS 3.1 assessment is 3.7 Low , with network access but high attack complexity and limited confidentiality impact. NVD itself currently has no NVD-assigned v3.x base score. (NVD)
VULN-03 — Apache httpd 2.2.8	CVE-2017-7679	CVSS 3.0	9.8	Critical	The vulnerability affects Apache httpd 2.2.x before 2.2.33, which includes the observed 2.2.8. NVD rates it 9.8 Critical , with network attack vector, low complexity, no privileges/user interaction, and high

					confidentiality, integrity and availability impact. (NVD)
--	--	--	--	--	---

Q13: Risk Matrix

Impact / Likelihood	Low	Medium	High
Low	Low	Low	Medium
Medium	Low	Medium	High
High	Medium	High	Critical

Finding	Likelihood	Impact	Risk Level	Reason
VULN-01	High	High	Critical	vsftpd 2.3.4 is associated with a known backdoor vulnerability that can allow remote unauthorized access, resulting in potentially severe confidentiality, integrity, and availability impact.
VULN-02	Low	Low	Low	CVE-2008-5161 has a relatively limited impact and requires specific conditions for exploitation; therefore, both likelihood and overall impact are assessed as low.
VULN-03	High	High	Critical	Apache httpd 2.2.8 falls within the affected range for CVE-2017-7679, which can have significant impact on the target when remotely exploited.

Q14: Cryptography and TLS Review

Test	Result	Evidence	Assessment
HTTP → HTTPS Redirect	Pass	HTTP/1.1 301 Moved Permanently → Location: https://www.hackthissite.org/	HTTP traffic is redirected to HTTPS.
HTTPS Availability	Pass	HTTP/2 200	HTTPS endpoint is reachable and functioning.
HSTS	Pass	strict-transport-security: max-age=31536000; includeSubDomains; preload	HSTS is enabled for 1 year, including subdomains, with preload requested.
CSP	Present	content-security-policy: ... upgrade-insecure-requests	CSP is configured and requests browsers to upgrade insecure requests.
Certificate/TLS Details	Not tested yet	Not present in the supplied curl output	Need openssl/Nmap TLS scan to verify certificate, TLS versions and ciphers.

Encryption	Keys	Use in HTTPS/TLS
Symmetric	Same secret key encrypts and decrypts data	Used for encrypting the actual application/session traffic because it is fast.
Asymmetric	Public key + private key	Used during the TLS handshake for authentication and establishing/protecting key material.

```
(kali@kali)~$ curl -I http://www.hackthissite.org
HTTP/1.1 301 Moved Permanently
Content-length: 0
Location: https://www.hackthissite.org/

(kali@kali)~$ curl -I https://www.hackthissite.org
HTTP/2 200
date: Mon, 24 Aug 2026 09:35:28 GMT
set-cookie: HackThisSite=rhmaitsmibkq6nqoho56gfh0q5; expires=Tue, 25-Aug-2026 09:35:28 GMT; path=/
expires: Thu, 19 Nov 1981 08:52:00 GMT
cache-control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0
pragma: no-cache
onion-location: http://hackthisjogneh42n5o7gbzrewxee3vyu6ex37ukyvdw6jm66npakiyd.onion/
content-type: text/html
content-language: en
server: HackThisSite
access-control-allow-origin: *
content-security-policy: child-src 'self' hackthissite.org *.hackthissite.org htscdn.org *.htscdn.org discord.com; form-action 'self' hackthissite.org *.hackthissite.org htscdn.org *.htscdn.org; upgrade-insecure-requests; report-uri https://hackthissite.report-uri.com/r/d/csp/enforce
referrer-policy: origin-when-cross-origin
x-xss-protection: 0
feature-policy: fullscreen *
public-key-pins-report-only: pin-sha256="YLh1dUR9y6Kja30RrAn7JKnBQG/uEtLMkBgFF2Fuhg="; pin-sha256="Vjs8r4z+80wjNcr1YKepWQboSIRi63WsWXhIMN+eWys="; max-age=2592000; includeSubDomains; report-uri="https://hackthissite.report-uri.com/r/d/hpkp/reportOnly"
strict-transport-security: max-age=31536000; includeSubDomains; preload
report-to: {"group": "default", "max_age": 31536000, "endpoints": [{"url": "https://hackthissite.report-uri.com/a/d/g"}], "include_subdomains": true}
nel: {"report_to": "default", "max_age": 31536000, "include_subdomains": true, "success_fraction": 0.0, "failure_fraction": 0.1}
```

Q15: Incident Response Plan

Phase	Actions
1. Detect	Identify indicators of compromise such as unusual login activity, unexpected processes, modified files, suspicious network connections, and abnormal database queries or data transfers. Review web-server, authentication, firewall, database, and system logs to determine the initial access point, affected systems, attack timeline, and scope of the data exposure. Preserve relevant logs and forensic evidence without modifying the original evidence.
2. Contain	Immediately isolate the affected server or vulnerable service from the network while maintaining necessary evidence. Disable or restrict the exploited service and apply temporary firewall/network controls. Disable compromised accounts, revoke active sessions and credentials, and rotate exposed passwords, API keys, and other secrets. Prevent further access to customer databases and identify whether other systems have been compromised.
3. Eradicate	Determine and remove the root cause of the compromise. Patch or upgrade the vulnerable software to a secure supported version and remove malicious files, accounts, scheduled tasks, backdoors, and unauthorized configuration changes. Reset credentials associated with the compromised environment. Conduct vulnerability scanning and security validation to confirm that the original attack path is no longer available.

4. Recover	Restore affected systems from known-good backups if their integrity cannot be trusted. Bring services back online gradually while monitoring logs, network traffic, authentication events, and database activity for signs of continued compromise. Validate system integrity and functionality before returning to normal operations. Notify affected stakeholders and customers as required by applicable laws and organizational policies. Document the incident, its impact, actions taken, and lessons learned.
-------------------	--

Incident Response Plan

The incident response lifecycle is Detect, Contain, Eradicate and Recover. The team should expand the plan with organization-specific contacts, escalation procedures, evidence handling and communication requirements if requested by the supervisor.

Phase 5: Final Deliverable

Q16: Write a 1-page, non-technical executive summary for a company CEO explaining the overall security posture, top 3 risks, and business impact

Executive Security Summary

Overview

A security assessment was conducted against the company's authorized lab environment to evaluate its external exposure, web services, software versions, and potential vulnerabilities. The assessment identified several publicly accessible services and outdated software components. While the assessment was performed in a controlled environment, the findings demonstrate security weaknesses that could create significant business risk if present in a production environment.

Overall, the security posture should be considered **high risk** due to the presence of outdated services, multiple exposed network services, and vulnerabilities with potentially serious consequences.

Top 3 Risks

1. Critical Vulnerabilities in Outdated Software

The assessment identified critical vulnerabilities associated with outdated versions of **vsftpd** and **Apache HTTP Server**. These weaknesses could potentially allow unauthorized access or compromise of the affected system.

Business impact: A successful attack could result in unauthorized access to company systems, theft or modification of sensitive information, service disruption, financial losses, and reputational damage.

2. Large Number of Exposed Network Services

The target exposed numerous services including FTP, SSH, Telnet, SMTP, HTTP, SMB, databases, VNC, IRC, and other network services. Every externally accessible service increases the potential attack surface.

Business impact: Attackers have more opportunities to discover weaknesses and gain unauthorized access. Compromise of one exposed service could potentially provide a pathway to other company resources.

3. Outdated and Vulnerable Technology Components

The assessment identified several legacy software versions, including outdated SSH, FTP, database, web-server, and Java-related services. Older software may no longer receive security updates and may contain publicly documented vulnerabilities.

Business impact: Continued use of unsupported or outdated technology increases the likelihood of successful attacks and can make incident response, compliance, and system recovery more difficult.

Overall Business Impact

If these weaknesses existed in a production environment, a successful compromise could affect the **confidentiality, integrity, and availability** of company information and services. Customer data could potentially be exposed, critical services could become unavailable, and the organization could face regulatory, financial, legal, and reputational consequences.

Recommended Management Priorities

Management should prioritize **patching or replacing outdated software**, reducing unnecessary internet-facing services, implementing strong access controls and network segmentation, and continuously monitoring systems for suspicious activity. Critical vulnerabilities should be addressed first, followed by medium- and low-risk weaknesses.

Overall assessment: High Risk — immediate remediation of critical vulnerabilities and unnecessary exposed services is recommended.

Q17. Compile all findings into a single professional Vulnerability Assessment Report.

Completed

Q18. Prepare a 10-minute presentation (max 10 slides) summarizing methodology, key findings, and top recommendations for Nimbus Retail Co.'s leadership team.

Completed

Haan. Agar tum **A, B, C, D** rakhna chahte ho, to tumhari report ke content ke according ye professional aur short tables best rahengi.

Appendix A: Evidence & Screenshot Register

ID	Evidence / Screenshot	Related Section	Description
A-01	Network Architecture Diagram	Q2	Segmented network design
A-02	OSINT / WHOIS Output	Q5	Domain registration and DNS information
A-03	Subdomain Enumeration Output	Q6	Discovered subdomains
A-04	Attack Surface Diagram	Q7	Discovered assets and relationships
A-05	Nmap Scan Output	Q8	Port and service enumeration
A-06	Service Version / Banner Output	Q9	Service and version identification
A-07	Web Technology Detection	Q10	Detected web technologies
A-08	NVD Evidence	Q11	CVE verification
A-09	TLS/HTTPS Test	Q14	HTTPS, HSTS and TLS evidence

Appendix B: Scan Logs & Technical Evidence

ID	Tool / Command	Target	Purpose	Result
B-01	whois hackthissite.org	Hack This Site	WHOIS enumeration	Domain information obtained
B-02	dig NS/A/MX/TXT hackthissite.org	Hack This Site	DNS enumeration	DNS records identified
B-03	subfinder -d hackthissite.org	Hack This Site	Subdomain discovery	Subdomains identified
B-04	httpx	Hack This Site	Web/technology detection	HTTP status and technologies identified
B-05	nmap 192.168.18.152	Metasploitable 2	Port scanning	Open ports identified
B-06	nmap -sV 192.168.18.152	Metasploitable 2	Version detection	Services and versions identified
B-07	nmap -O 192.168.18.152	Metasploitable 2	OS detection	Linux OS identified
B-08	nmap -sS 192.168.18.152	Metasploitable 2	SYN scan	Open TCP ports identified
B-09	curl -I http://www.hackthissite.org	Hack This Site	HTTPS redirect test	HTTP → HTTPS redirect
B-10	curl -I https://www.hackthissite.org	Hack This Site	HTTPS header review	HSTS/CSP observed

Appendix C: References

C.1 National Vulnerability Database (NVD)

National Institute of Standards and Technology (NIST). **National Vulnerability Database — CVE-2011-2523: vsftpd 2.3.4 vulnerability.**

[NVD — CVE-2011-2523](#)

National Institute of Standards and Technology (NIST). **National Vulnerability Database — CVE-2008-5161:**

OpenSSH vulnerability.

[NVD — CVE-2008-5161](#)

National Institute of Standards and Technology (NIST). **National Vulnerability Database — CVE-2017-7679: Apache HTTP Server vulnerability.**

[NVD — CVE-2017-7679](#)

C.2 CVSS

FIRST. **Common Vulnerability Scoring System (CVSS), Version 3.1.**

[FIRST — CVSS v3.1](#)

This reference supports the CVSS methodology and severity ratings used in Q12.

C.3 OWASP

OWASP Foundation. **OWASP Top 10: The Ten Most Critical Web Application Security Risks.**

[OWASP Top 10](#)

This reference supports the OWASP categories discussed in the Web Technology and OWASP Relevance section.

C.4 Nmap

Nmap Project. **Nmap Reference Guide — Service and Version Detection (-sV) and scanning techniques.**

[Nmap Reference Guide](#)

This reference supports the Nmap commands and scanning methodology used in Phase 3.

C.5 Hack This Site

Hack This Site. **Hack This Site — Authorized Training Environment.**

[Hack This Site](#)

Used as the authorized web-focused training environment for reconnaissance and web-security assessment activities.

C.6 Metasploitable 2

Rapid7. **Metasploitable 2 — Vulnerable Virtual Machine for Security Testing.**

[Rapid7 Metasploitable 2](#)

Used as the authorized vulnerable laboratory target for network enumeration and service/version identification.

C.7 CIA Triad / Cybersecurity Guidance

National Institute of Standards and Technology (NIST). **The NIST Cybersecurity Framework (CSF) 2.0.**

[NIST Cybersecurity Framework 2.0](#)

Used as supporting cybersecurity guidance for security posture, risk management, and organizational security practices.

C.8 TLS / HTTPS

Mozilla. **Server-side TLS configuration guidance.**

[Mozilla SSL Configuration Generator](#)

Used as supporting guidance for evaluating secure TLS configuration and HTTPS deployment.

C.9 Incident Response

National Institute of Standards and Technology (NIST). **Computer Security Incident Handling Guide, SP 800-61.**

[NIST SP 800-61](#)

Used as supporting guidance for the incident response lifecycle and response planning.

C.10 Real-World Breach References

U.S. Securities and Exchange Commission. **MGM Resorts International — Form 8-K, September 2023.**

[SEC — MGM Resorts Filing](#)

U.S. Department of Health and Human Services. **Change Healthcare Cybersecurity Incident.**

[HHS — Change Healthcare Cybersecurity Incident](#)

Appendix D: Submission Checklist

Requirement	Status
Report.pdf	✓ Completed
Network Diagram	✓ Completed
Screenshots / Scan Logs	✓ Completed
Vulnerability Findings	✓ Completed
Risk Matrix	✓ Completed
TLS/Cryptography Review	✓ Completed
Incident Response Plan	✓ Completed
Executive Summary	✓ Completed
Presentation.pdf	✓ Completed
LinkedIn Link	☐ Add Link
GitHub Link	☐ Add Link